

Governance Review Card

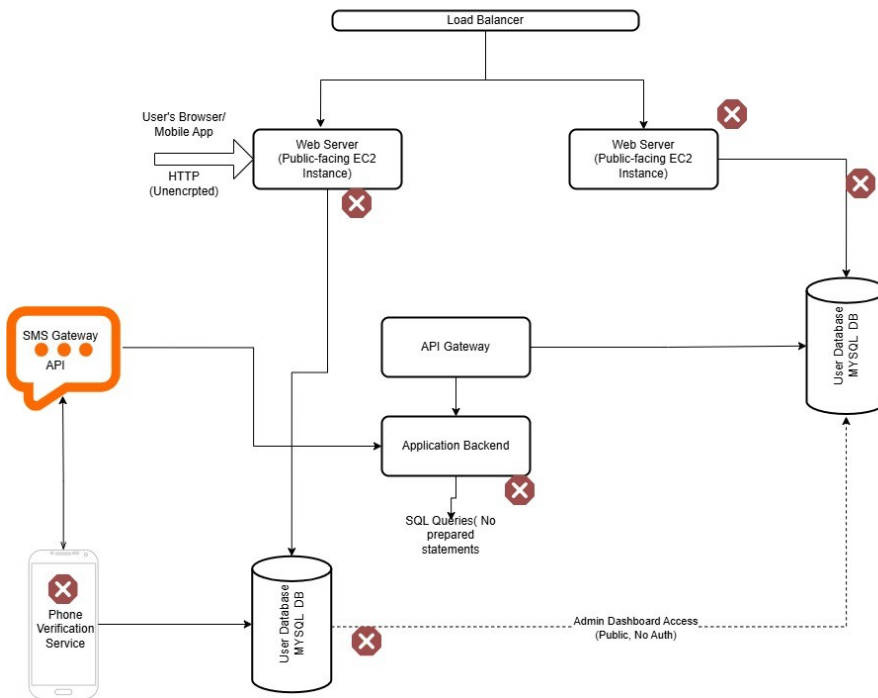
Section	Issue/ Definition	Impact	Suggested fix/ Mitigation
1. Confidentiality Risk	HTTP is used for client traffic and the databases/admin path is exposed or insufficiently isolated. This violates the CIA Triad's Confidentiality principle.	PII such as names, emails and phone numbers could be intercepted or disclosed; database exposure could cause a large-scale privacy breach.	Enforce HTTPS/TLS end-to-end, redirect HTTP to HTTPS, place databases in private subnets, restrict security-group access, encrypt sensitive data at rest, and use a secrets manager.
2. Integrity Risk	The application uses SQL queries without prepared statements and has weak input validation. This conflicts with Input Validation and Secure SDLC principles.	An attacker could inject SQL, modify/delete records, bypass application logic, or corrupt user/event data.	Use parameterized queries/ORM, strict server-side validation, output encoding, allow-lists where appropriate, and automated security tests in CI/CD.
3. Availability Risk	Public-facing infrastructure has no visible rate limiting, monitoring, or incident-response capability, increasing the risk of resource exhaustion and prolonged outages. This concerns the Availability leg of the CIA Triad.	Abuse or an attack could exhaust web/API/database resources, interrupt messaging or registration, and reduce trust during events.	Add API/WAF rate limiting, autoscaling/health checks, database backups and tested restoration, centralized monitoring, alerting, and an incident-response runbook.

Monitoring / Reporting Recommendation

Metric to Monitor	Definition	Visualization Type	Why It Matters
Failed authentication / authorization rate	Number of failed login, token-validation, and authorization requests per minute, segmented by endpoint and source.	Line chart with threshold/alert markers	A sudden increase can reveal credential attacks, privilege-abuse attempts, or misconfigured clients early enough for investigation and response.

The numbered panel gives the annotation and governance rationale for each correction.

ConnectSphere User Flow (Set 1)



SET 1 — PROPOSED SECURITY

- 1 TLS / HTTPS everywhere**
Replace HTTP with HTTPS from browser/app to load balancer and web tier. Use TLS certificates and redirect HTTP to HTTPS. Protects PII in transit (Confidentiality).
- 2 Private database + network isolation**
Move both MySQL databases to private subnets; allow access only from the application tier through security groups. Remove direct/public database paths (PoLP).
- 3 Secure API authorization**
Require authenticated sessions/tokens and server-side RBAC on every API endpoint. Users may access only their own profile/registration data (Least Privilege).
- 4 Parameterized SQL + validation**
Replace raw SQL with parameterized queries/ORM and validate/encode all input at the API boundary. Prevent SQL injection and data tampering (Integrity + Input Validation).
- 5 Secure sessions + secrets**
Use short-lived secure cookies/tokens, rotation and server-side expiry. Store API/database secrets in a secrets manager, never frontend code.

Set 1 Summary of review process

I reviewed the Set 1 architecture by tracing the main user-data flows from the browser/mobile application through the load balancer, web servers, API/backend, SMS verification service, and MySQL databases. I first applied the CIA Triad to identify where confidentiality, integrity, and availability could be compromised. The clearest confidentiality weaknesses were unencrypted HTTP and insufficient database isolation. Integrity was at risk because the diagram explicitly shows SQL queries without prepared statements and because input validation is not defined. Availability was assessed through the public-facing infrastructure, lack of rate limiting, and absence of monitoring and incident-response controls.

I then applied the Principle of Least Privilege to the API, database, and administrative paths. Each user and service should receive only the permissions required for its role, while administrative functions should require authenticated, authorized access. Secure SDLC principles were applied by recommending parameterized queries, validation, security testing in CI/CD, secure session management, and review of infrastructure configuration before deployment.

These changes strengthen ConnectSphere's data-protection posture by reducing unauthorized disclosure, manipulation, and service disruption. They also support GDPR/CCPA-aligned practices such as protecting personal information, restricting access, and maintaining accountability. The recommended failed-authentication/authorization rate is ethically useful because it provides a measurable signal of possible abuse without requiring unnecessary collection of personal content. Centralized, access-controlled logs and documented incident response make security decisions more transparent, auditable, and repeatable.